

AWS DEVOPS INTERVIEW GUIDE

Scenario 1: Secure a Three-Tier Production Application

Scenario

Your company is deploying an e-commerce application consisting of:

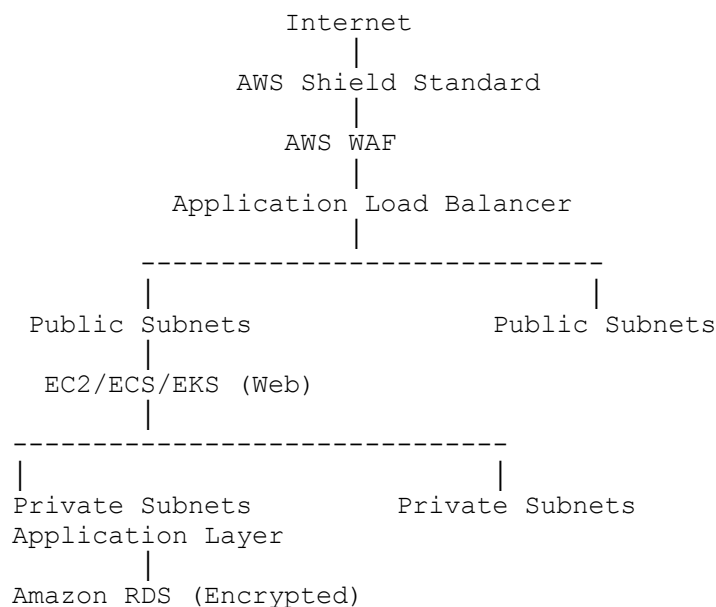
- Web Tier
- Application Tier
- Database Tier

The application contains customer payment information and must follow AWS security best practices.

How would you secure the entire architecture?

Solution

Architecture



Security Measures

Network Security

- Public access only through ALB
 - Application servers in private subnets
 - Database in private subnet
 - NAT Gateway for outbound internet
 - Restrictive Security Groups
 - NACLs as an additional network layer
-

Identity Security

- IAM Roles instead of Access Keys
 - Least Privilege Principle
 - Multi-Factor Authentication (MFA)
 - IAM Access Analyzer
-

Data Security

- RDS Encryption (KMS)
 - EBS Encryption
 - S3 Encryption
 - Secrets Manager for passwords
-

Monitoring

- CloudTrail
 - GuardDuty
 - Security Hub
 - AWS Config
 - CloudWatch
-

Interview Keywords

- Defense in Depth
 - Zero Trust
 - Encryption at Rest
 - Encryption in Transit
-

Scenario 2: Developer Stored AWS Access Keys Inside Application

Scenario

A developer committed the following into GitHub:

```
AWS_ACCESS_KEY
```

```
AWS_SECRET_KEY
```

How would you fix this?

Solution

Immediately perform the following:

Step 1

Deactivate the Access Keys.

Step 2

Generate new credentials if required.

Step 3

Attach an IAM Role to the workload.

```
EC2
```

```
↓
```

```
IAM Role
```

```
↓
```

```
Temporary Credentials
```

```
↓
```

```
AWS Services
```

Step 4

Remove secrets from Git history.

Step 5

Enable secret scanning.

Examples:

- GitHub Secret Scanning
- Git hooks
- TruffleHog
- Gitleaks

Prevention

- IAM Roles
- Secrets Manager
- No credentials inside code

Scenario 3: EC2 Instance Compromised

Scenario

A production EC2 instance has been compromised.

How would you respond?

Solution

Step 1

Isolate the instance.

Remove from:

- ALB
 - Auto Scaling
 - Security Groups
-

Step 2

Capture evidence.

- EBS Snapshot
 - Memory dump (if required)
 - CloudTrail logs
 - VPC Flow Logs
-

Step 3

Do NOT terminate immediately.

Preserve forensic evidence.

Step 4

Launch a clean EC2 instance.

Step 5

Rotate

- IAM Credentials
 - Secrets
 - API Keys
 - Database Passwords
-

Step 6

Root Cause Analysis

Determine:

- Vulnerability exploited
 - Timeline
 - Impact
 - Data exposure
-

Scenario 4: Cross-Account Access Required

Scenario

Jenkins in one AWS account needs to deploy applications into Production in another AWS account.

How would you secure this?

Solution

Use

Cross-Account IAM Roles.

Jenkins

↓

IAM Role

↓

STS AssumeRole

↓

Production Account

↓

Deployment

Benefits

- No production access keys
 - Temporary credentials
 - Least privilege
 - Easy auditing
-

Scenario 5: Secure Database Credentials

Scenario

Developers store database passwords inside:

`application.properties`

How would you improve security?

Solution

Use

AWS Secrets Manager.

Secrets Manager

↓

IAM Role

↓

Application

↓

Database

Benefits

- Encryption
 - Rotation
 - IAM Authentication
 - Audit Trail
-

Scenario 6: S3 Bucket Became Public Accidentally

Scenario

A production S3 bucket containing customer documents became publicly accessible.

How would you respond?

Solution

Immediate Actions

Disable

Public Access

Enable

Block Public Access

Verify

Bucket Policy

IAM Policy

ACL

Audit

CloudTrail

Who modified the bucket?

When?

Prevention

- AWS Config Rule
 - S3 Block Public Access
 - Security Hub
 - IAM Least Privilege
-

Scenario 7: IAM User Has AdministratorAccess

Scenario

A developer requests:

AdministratorAccess

to troubleshoot an issue.

Would you approve?

Solution

No.

Follow Least Privilege.

Example

Instead of

`AdministratorAccess`

Grant

`CloudWatchReadOnly`

`EC2ReadOnly`

`S3ReadOnly`

Or create a custom policy with only the required permissions.

Interview Tip

Administrator access should be:

- Temporary
 - Approved
 - Audited
-

Scenario 8: Protect Application Against DDoS Attacks

Scenario

An e-commerce website receives millions of malicious requests.

How would AWS protect it?

Solution

Architecture

Internet

↓

AWS Shield

↓

AWS WAF

↓

CloudFront

↓

ALB

↓

Application

Services

AWS Shield Standard

Protects against:

- SYN Flood
- UDP Flood
- Network attacks

AWS WAF

Blocks:

- SQL Injection
- XSS
- Bots
- IP Reputation Lists

CloudFront

Absorbs global traffic.

Scenario 9: Unauthorized API Calls Were Made

Scenario

CloudTrail shows someone deleted EC2 instances.

How would you investigate?

Solution

Review

CloudTrail

Look for:

`TerminateInstances`

Determine:

- IAM User
 - Role
 - Source IP
 - MFA used?
 - Time
 - Region
-

Also review:

- GuardDuty
 - AWS Config Timeline
 - CloudWatch Logs
-

Recovery

Restore from:

- Auto Scaling
- AMI
- Terraform

Scenario 10: Secure an EKS Cluster

Scenario

Your Kubernetes cluster contains production banking applications.

How would you secure it?

Solution

Security

Private API Endpoint

Managed Node Groups

IRSA

Network Policies

Secrets Manager

Pod Security Standards

Image Scanning

Security Groups

Monitoring

CloudTrail

GuardDuty

Container Insights

Prometheus

Falco (optional runtime security)

Best Practices

- No privileged containers
 - Read-only root filesystem where feasible
 - Least privilege RBAC
 - Regular patching
-

Scenario 11: Encrypt All Production Data

Scenario

Management requires all data to be encrypted both at rest and in transit.

How would you implement this?

Solution

At Rest

- S3 SSE-KMS
 - EBS Encryption
 - RDS Encryption
 - EFS Encryption
-

In Transit

HTTPS

TLS

ACM Certificates

Key Management

AWS KMS

Customer Managed Keys

Automatic Rotation

Scenario 12: Detect Security Threats Automatically

Scenario

The security team wants automatic detection of suspicious AWS activities.

Solution

Use

AWS GuardDuty.

Detects

- Cryptocurrency mining
 - IAM anomalies
 - Port scanning
 - Credential compromise
 - Malware indicators
-

Also integrate

Security Hub

CloudTrail

CloudWatch

SNS

Scenario 13: Company Must Meet Compliance Requirements

Scenario

The organization needs continuous compliance monitoring for standards such as PCI DSS, ISO 27001, or CIS benchmarks.

How would you implement this?

Solution

Use

AWS Config

Create rules.

Examples

S3 Public?

No

EBS Encrypted?

Yes

CloudTrail Enabled?

Yes

Combine with

Security Hub

AWS Audit Manager

AWS Config Conformance Packs

Scenario 14: Secure a CI/CD Pipeline

Scenario

Your Jenkins pipeline deploys infrastructure and applications to AWS.

How would you secure it?

Solution

Pipeline

GitHub

↓

Jenkins

↓

SonarQube

↓

Trivy

↓

Build

↓

Terraform

↓

Deploy

Security Controls

- IAM Roles (no access keys)
- Secrets Manager
- Branch protection
- Code reviews
- Artifact signing (where applicable)
- Image scanning
- Least privilege deployment role
- Manual approval for production

Scenario 15: Respond to a Production Security Incident

Scenario

Your Security Operations Center reports suspicious activity in your AWS environment.

How would you handle the incident?

Solution

Step 1

Identify

- Which resource?
- Which account?
- Which region?

Step 2

Contain

- Isolate EC2
- Disable compromised IAM credentials
- Block malicious IPs using WAF or Security Groups

Step 3

Investigate

CloudTrail

GuardDuty

CloudWatch

VPC Flow Logs

AWS Config

Step 4

Recover

Deploy clean infrastructure using:

- Terraform
- CloudFormation
- AMIs

- Auto Scaling

Step 5

Root Cause Analysis

Document:

- Timeline
- Root Cause
- Business Impact
- Corrective Actions
- Preventive Measures

AWS Security Interview Cheat Sheet

AWS Service	Purpose
IAM	Identity and access management
IAM Roles	Temporary credentials for AWS resources
STS	Provides temporary security credentials
KMS	Encryption key management
Secrets Manager	Secure storage and rotation of secrets
Systems Manager Parameter Store	Store configuration and secrets (with optional encryption)
AWS WAF	Protects web applications from common web exploits
AWS Shield	DDoS protection
CloudTrail	Records AWS API activity
GuardDuty	Intelligent threat detection
Security Hub	Centralized security findings
AWS Config	Resource configuration tracking and compliance
AWS Audit Manager	Helps collect evidence for compliance audits
ACM	SSL/TLS certificate management
Inspector	Vulnerability assessment for EC2, ECR, and Lambda
Macie	Discovers and protects sensitive data in S3
Detective	Investigates and analyzes security incidents
VPC Flow Logs	Network traffic logging
Network Firewall	Stateful network filtering at the VPC level
Cognito	Authentication and user identity for applications

Production Security Best Practices

- Follow the **Principle of Least Privilege**.
- Use **IAM Roles** instead of long-lived access keys.
- Enable **MFA** for privileged users.
- Encrypt all sensitive data using **AWS KMS**.
- Store credentials in **AWS Secrets Manager**.
- Enable **CloudTrail** in all regions.
- Use **GuardDuty**, **Security Hub**, and **AWS Config** for continuous monitoring.
- Keep workloads in **private subnets** whenever possible.
- Protect internet-facing applications with **CloudFront**, **AWS WAF**, and **AWS Shield**.
- Patch operating systems and container images regularly.
- Scan container images using **Amazon Inspector**, **Trivy**, or similar tools.
- Use **Infrastructure as Code** (Terraform/CloudFormation) to maintain consistent, auditable environments.
- Conduct periodic security reviews, penetration testing (within AWS policy), and disaster recovery exercises.